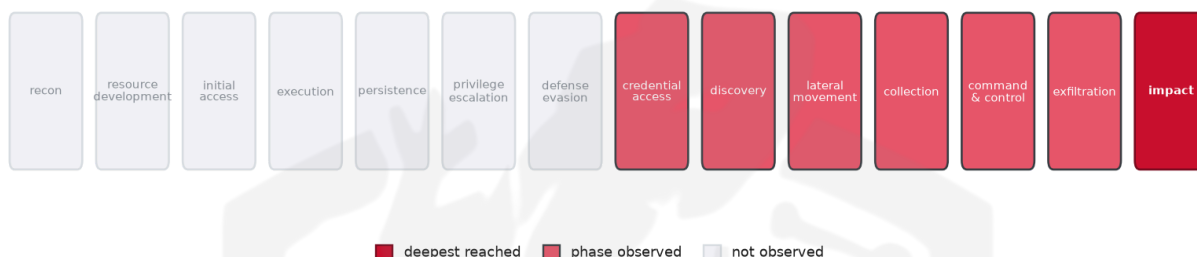


# THREAT REPORT: AURORA EXPLOITS SMB RELAY VIA CVE-2017-0144

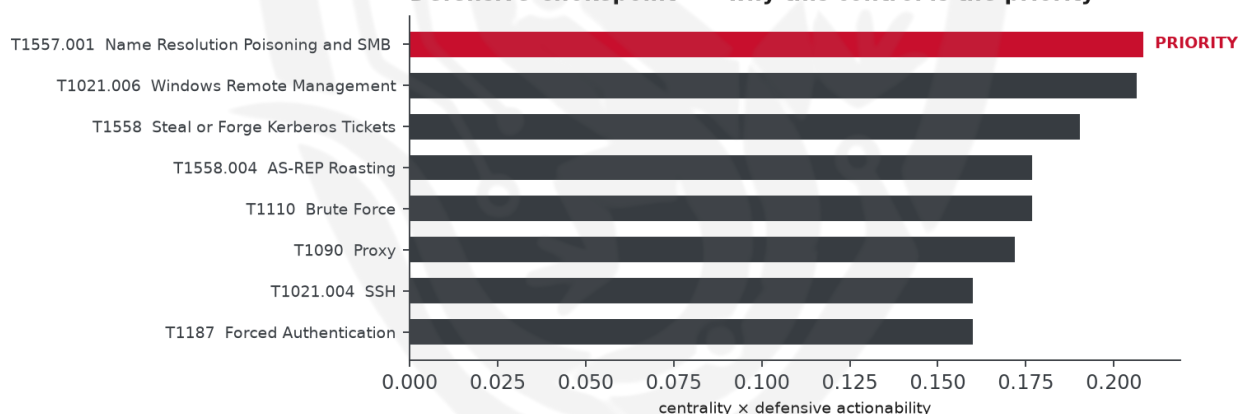
## Visual Summary

### Kill-Chain Reach — Critical (deepest phase reached: impact)



How far down the attack chain this campaign reached; deepest phase in crimson.

### Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

## Summary

The threat actor Aurora is leveraging the SMB relay technique (T1557.001) that exploits the Windows SMB vulnerability identified as CVE-2017-0144. A diverse set of malware families—including HydraQ, Roarur, MdmBot, HomeUnix, Homux, McRat, and the 9002 RAT—are used to compromise victims in the United States and Germany across manufacturing, agriculture, finance, transportation, retail, technology, and healthcare sectors. The activity culminates in credential theft, domain-trust discovery, and data encryption for impact. Priority should be given to enforcing phishing-resistant (FIDO2) multi-factor authentication with token binding, monitoring for anomalous device or geographic token use, blocking look-alike domains at the proxy, and patching CVE-2017-0144 on all vulnerable systems.

## Threat Overview

Aurora employs a suite of malware families (HydraQ, Roarur, MdmBot, HomeUnix, Homux, McRat, 9002 RAT) to exploit the SMB vulnerability CVE-2017-0144. The campaign targets organizations in the United States and Germany, spanning sectors such as manufacturing, agriculture, finance, transportation, retail, technology, and healthcare.

## Attack Chain and Priority Control

---

The observed attack proceeds through a series of techniques: initial name-resolution poisoning and SMB relay (T1557.001) to achieve a man-in-the-middle position; credential dumping via SAM, Security Account Manager, and NTDS (T1003, T1003.002, T1003.003); discovery of permission groups, accounts, domain trusts, and remote systems (T1069, T1087, T1482, T1018); lateral movement using SSH and Windows Remote Management (T1021.004, T1021.006); brute-force and AS-REP/kerberoasting attacks (T1110, T1558, T1558.003, T1558.004, T1187); proxying traffic (T1090); exfiltration over web services (T1567); and finally data encryption for impact (T1486, T1490).

**Priority technique:** T1557.001 Name Resolution Poisoning and SMB Relay

**Priority control (verbatim):**

*Defeat adversary-in-the-middle: enforce phishing-resistant (FIDO2) MFA and token binding; alert on new-device/new-geo token use and impossible-travel; block newly registered look-alike domains at the proxy. In parallel, patch CVE-2017-0144 on all affected systems.*

## Infrastructure and Corroboration

---

The enrichment data reports no identified hosting providers or ASNs associated with this activity, no high-confidence AbuseIPDB flags, and no malware families corroborated by abuse.ch.

---

## Technical Appendix

---

*Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.*

### Observed Techniques (ATT&CK, expert-tagged by source)

- T1557 Adversary-in-the-Middle
- T1003 OS Credential Dumping
- T1069 Permission Groups Discovery
- T1003.002 Security Account Manager
- T1489 Service Stop
- T1021.004 SSH
- T1558.004 AS-REP Roasting
- T1558 Steal or Forge Kerberos Tickets
- T1567 Exfiltration Over Web Service
- T1021.006 Windows Remote Management
- T1557.001 Name Resolution Poisoning and SMB Relay
- T1087 Account Discovery

- T1090 Proxy
- T1482 Domain Trust Discovery
- T1110 Brute Force
- T1187 Forced Authentication
- T1486 Data Encrypted for Impact
- T1018 Remote System Discovery
- T1003.003 NTDS
- T1558.003 Kerberoasting
- T1490 Inhibit System Recovery

## Analytical Scores

- Priority technique (graph chokepoint): T1557.001 Name Resolution Poisoning and SMB Relay (centrality 0.2977).
- Operational risk: Critical (score 1.0, reaches impact).

## Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3185; reference threshold  $\tau = 0.6$ ).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

| Historical Profile | Behavioural Overlap |
|--------------------|---------------------|
| Wizard Spider      | 0.3185              |
| Indrik Spider      | 0.2865              |
| Akira              | 0.2673              |
| Medusa Group       | 0.2651              |
| Scattered Spider   | 0.2635              |

## Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

## Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

| Type   | Indicator                                                        |
|--------|------------------------------------------------------------------|
| Domain | ijexszhscln27nl263lmcd7tx3jttkhm4wjhd4e3y6r4csdbfyepriid[.]onion |
| Hash   | a4af136d159a8eb96b54924fa80355ca52874913301300f55af7d67ae97edcfe |
| Hash   | eb0aab1e892d7e09e2c7bcf1d21fd83c1743ed9196b3efac6c78482fb0d99207 |

## Flame Cell // Adversary Pivot [ BETA ]

*BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? [norbert@salacti.com](mailto:norbert@salacti.com)*

- **Control applied:** T1557.001 Name Resolution Poisoning and SMB Relay (credential-access)
- **Observed here:** T1557.001 Name Resolution Poisoning and SMB Relay was the only credential-access technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1056 Input Capture (credential-access)
- **Basis:** of the 3+ groups that use Name Resolution Poisoning and SMB Relay, this pairing runs 2.2x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1557.001 Name Resolution Poisoning and SMB Relay blocked, Aurora could preserve the same objective by pivoting to T1056 Input Capture, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Alert on keylogging hooks and API-input capture; restrict accessibility/hook installation.

- **Defensive countermeasure:** Alert on keylogging hooks and API-input capture; restrict accessibility/hook installation.